

LINDDUN threat

Owner: Renad Albladi , Ghadah Alharthi , Raghad Alowaybidi , Rehanah Bugis

Reviewer:

Contributors:

Date Generated: Tue Oct 29 2024

Executive Summary

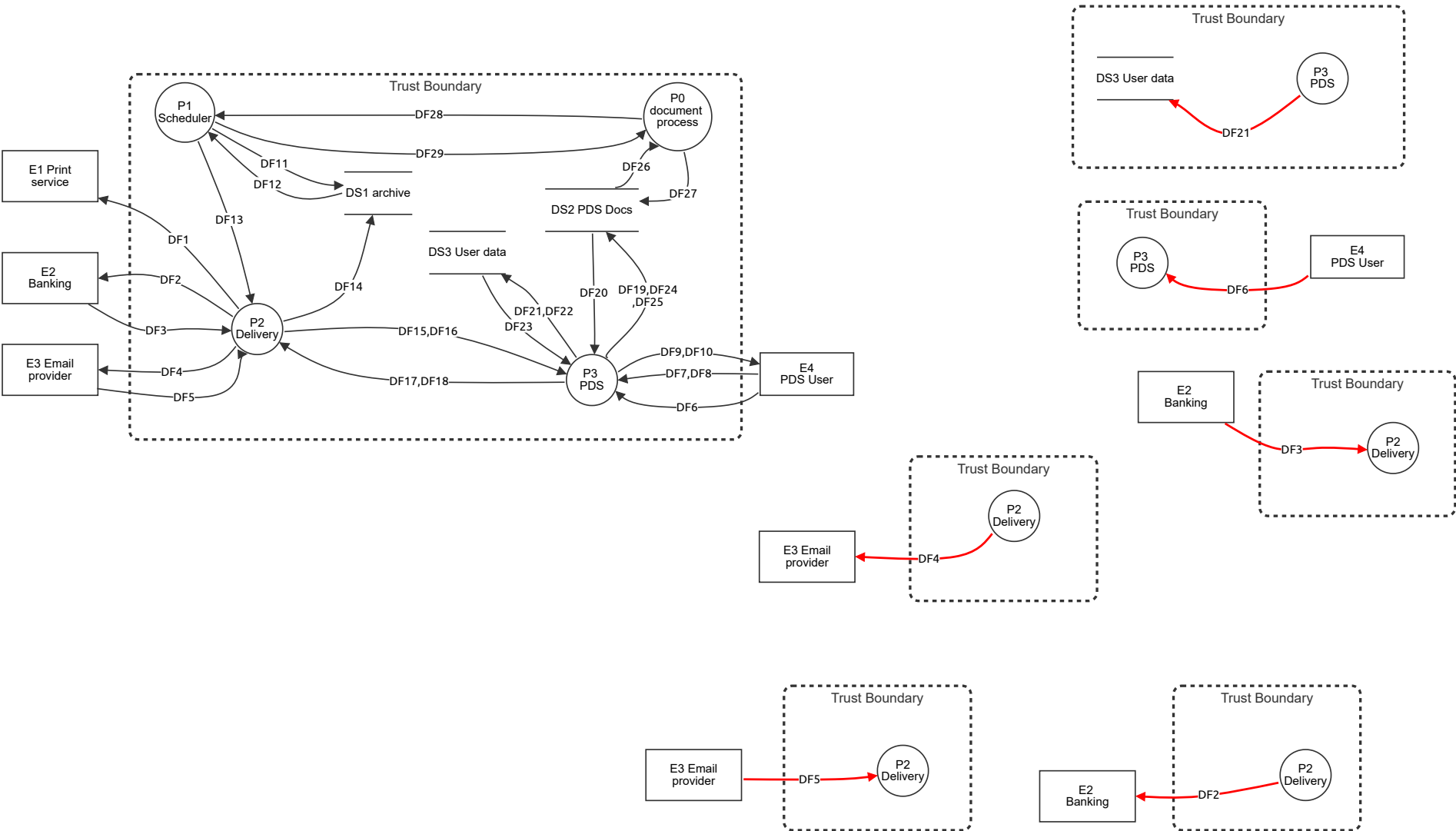
High level system description

Not provided

Summary

Total Threats	6
Total Mitigated	0
Not Mitigated	6
Open / High Priority	1
Open / Medium Priority	5
Open / Low Priority	0
Open / Unknown Priority	0

New LINDDUN diagram



New LINDDUN diagram

DF6 (Data Flow)

Data transfer between the user and the PDS process, where the data is the login cred+ doc ID

Number	Title	Type	Priority	Status	Score	Description	Mitigations																		
18	L ON DF6	Detectability	Medium	Open	4	Source: For threats at the source we look at D.3, which can occur when the user enters the wrong password and the system responses and an error message reveals the existence of the account. Data Flow: any data exchanges that can be monitored by an adversary. This includes requests sent over the internet, or web services. So, when the user requests to login, the adversary may monitor the network traffic and see when and where requests are being sent even if they are encrypted and they can't read the content of those requests. <table><tr><td>S</td><td>Fl</td><td>R</td><td>Location</td><td>Characteristics</td><td>Description</td></tr><tr><td>E4</td><td>DF6</td><td>P3</td><td>E4</td><td>D.3</td><td>System responses</td></tr><tr><td>E4</td><td>DF6</td><td>P3</td><td>DF6</td><td>D.1</td><td>Detecting through observed communications</td></tr></table>	S	Fl	R	Location	Characteristics	Description	E4	DF6	P3	E4	D.3	System responses	E4	DF6	P3	DF6	D.1	Detecting through observed communications	For System responses: 1-Generic Error Messages Implement generic error messages for login attempts. Instead of specifying whether the username or password is incorrect, use a message like "Invalid login credentials." This prevents adversaries from determining if an account exists based on specific error responses. 2-Rate Limiting Apply rate limiting to login attempts to slow down potential attackers. This makes it difficult for them to perform rapid, successive login attempts. For Detecting through observed communications: Network Traffic Monitoring Employ network monitoring tools to detect unusual traffic patterns, indicating potential attacks. This can help in early detection of malicious activities.
S	Fl	R	Location	Characteristics	Description																				
E4	DF6	P3	E4	D.3	System responses																				
E4	DF6	P3	DF6	D.1	Detecting through observed communications																				

DF21 (Data Flow)

Data flow 21 contains new user information such as (email, name, address, password) and is transferred from the PDS process to the user's database.

Number	Title	Type	Priority	Status	Score	Description	Mitigations																														
21	L on DF21	Identifiability	Medium	Open	3	Source: For threats at the source P3 we look at I.1.1 (Processing of identified data), which can occur when the process 3 processes identified data such as Identification based on username. The username for a service contains identity data (e.g., "firstname.lastname"). Also the DF21 contains combinations of attributes that are unique to a specific user. So, I.2.1.2 (Quasi-identifier) can also happen if there is a data leak. Data Flow: The data flow contains new user information such as email, name, address, and password, would fall under the "I.1.2 Identified information in metadata" . The metadata of communication involves identified information. and we look at the transfer of the information itself. This means the information being transferred from P3 to the user's data store is directly linked to a specific individual and can be used to identify them. Destination Finally, we look at the destination to consider the presence of Identifying threats. When we look at I.1.2 "Identified information in metadata", The user database contains information that reveals their identity. This data will be clear and reveal the identity of the users if the attacker has the ability to obtain it in some way. <table><tr><td>S</td><td>Fl</td><td>R</td><td>Location</td><td>Characteristics</td><td>Description</td></tr><tr><td>P3</td><td>DF21</td><td>DS3</td><td>P3</td><td>I.1.1</td><td>Processing of identified data</td></tr><tr><td>P3</td><td>DF21</td><td>DS3</td><td>P3</td><td>I.2.1.2</td><td>Quasi-identifier,combinations of attributes</td></tr><tr><td>P3</td><td>DF21</td><td>DS3</td><td>DS3</td><td>I.1.2</td><td>Identified information in metadata</td></tr><tr><td>P3</td><td>DF21</td><td>DS3</td><td>DF21</td><td>I.1.2</td><td>Identified information in metadata</td></tr></table>	S	Fl	R	Location	Characteristics	Description	P3	DF21	DS3	P3	I.1.1	Processing of identified data	P3	DF21	DS3	P3	I.2.1.2	Quasi-identifier,combinations of attributes	P3	DF21	DS3	DS3	I.1.2	Identified information in metadata	P3	DF21	DS3	DF21	I.1.2	Identified information in metadata	1. Mitigating Threats at the Source (P3) -Processing of Identified Data (Username) Implement privacy-preserving techniques when processing identified data, such as: Using pseudonymization: Replace the username with a non-identifying pseudonym. -Quasi-identifier (Combination of Attributes) Perform data anonymization or aggregation to remove the unique combination of attributes that could identify individual users. Identified Information in Metadata 2. Mitigating Threats at Data Flow (DF21) -Encrypt the metadata associated with the data flow to protect the identified information (email, name, address, password) during transmission. -Utilize secure communication protocols (e.g., HTTPS, TLS) to ensure end-to-end encryption of the data flow. 3.Mitigating Threats at the Destination (User Database) -Implement strong access controls and role-based permissions to limit access to the user database. -Ensure the user database is stored and secured using industry-standard encryption techniques to protect the identified information.
S	Fl	R	Location	Characteristics	Description																																
P3	DF21	DS3	P3	I.1.1	Processing of identified data																																
P3	DF21	DS3	P3	I.2.1.2	Quasi-identifier,combinations of attributes																																
P3	DF21	DS3	DS3	I.1.2	Identified information in metadata																																
P3	DF21	DS3	DF21	I.1.2	Identified information in metadata																																

DF4 (Data Flow)

Data transfer between the Delivery and the email provider, where the data is sent to the email provider to be sent via email to the customer.

Number	Title	Type	Priority	Status	Score	Description	Mitigations																								
16	L on DF4	Linkability	High	Open	5	Source If Delivery is accessed by unauthorized parties, the unique identifier could be exploited to track user information or obtain personal data. Data Flow If an attacker gains access to information in the dataflow that may contain Quasi-identifier combining data of a single individual, the attacker can use it to access external information. Destination Through inference or derivation, an email provider can personalize ads or recommendations based on indirect data inferred from user activities. This may lead to an improved user experience but also poses a privacy risk, as the user may feel monitored or that their data is being used for commercial purposes without their explicit consent. <table><thead><tr><th>S</th><th>Fl</th><th>R</th><th>Location</th><th>Characteristics</th><th>Description</th></tr></thead><tbody><tr><td>P2</td><td>DF4</td><td>E3</td><td>E3</td><td>L.1.1</td><td>Unique identifier</td></tr><tr><td>P2</td><td>DF4</td><td>E3</td><td>DF4</td><td>L.2.1.1</td><td>Quasi-identifier combining data of a single individual</td></tr><tr><td>P2</td><td>DF4</td><td>E3</td><td>P2</td><td>L.2.2</td><td>Through Profiling, derivation, or inference</td></tr></tbody></table>	S	Fl	R	Location	Characteristics	Description	P2	DF4	E3	E3	L.1.1	Unique identifier	P2	DF4	E3	DF4	L.2.1.1	Quasi-identifier combining data of a single individual	P2	DF4	E3	P2	L.2.2	Through Profiling, derivation, or inference	For Unique identifier: Encrypt Unique Identifiers Use encryption to protect unique identifiers during storage and transmission. For Quasi-identifier combining data of a single individual: Data Minimization Collect only data necessary to perform the required function, and avoid collecting semi-unique identifiers such as IP addresses or location data unless necessary. For Through Profiling, derivation, or inference: Data Obfuscation and Pseudonymization Use obfuscation and identity replacement techniques to make it difficult to link individual behaviors to users, while avoiding retaining information that could be used to build an accurate profile about individuals.
S	Fl	R	Location	Characteristics	Description																										
P2	DF4	E3	E3	L.1.1	Unique identifier																										
P2	DF4	E3	DF4	L.2.1.1	Quasi-identifier combining data of a single individual																										
P2	DF4	E3	P2	L.2.2	Through Profiling, derivation, or inference																										

DF3 (Data Flow)

Data transfer between the bank and the Delivery and the data sent are invoices

Number	Title	Type	Priority	Status	Score	Description	Mitigations																								
12	L on DF3	Disclosure of information	Medium	Open	3	Source The threat here could be that the bank is sending or giving data to people who are not supposed to see it. Data Flow Dataflow can include information such as invoices and other information such as IP that can be used by hackers. Destination Delivery can keep information for a longer period than necessary, which benefits from storing it for a longer period to provide services quickly, but it will expose it to risk. <table><tr><th>S</th><th>Fl</th><th>R</th><th>Location</th><th>Characteristics</th><th>Description</th></tr><tr><td>E2</td><td>DF3</td><td>P2</td><td>E3</td><td>DD4.1</td><td>Involved parties</td></tr><tr><td>E2</td><td>DF3</td><td>P2</td><td>DF3</td><td>DD3.3</td><td>Implicit data disclosure</td></tr><tr><td>E2</td><td>DF3</td><td>P2</td><td>P2</td><td>DD3.4</td><td>Duration/retention</td></tr></table>	S	Fl	R	Location	Characteristics	Description	E2	DF3	P2	E3	DD4.1	Involved parties	E2	DF3	P2	DF3	DD3.3	Implicit data disclosure	E2	DF3	P2	P2	DD3.4	Duration/retention	For Involved parties: -Clearly define and document the roles and responsibilities of all involved parties in data processing. - Implement strict access controls and logging mechanisms to monitor and audit data access and usage. For Implicit data disclosure Implement data minimization: Collect and retain only the minimum amount of data necessary to achieve the legitimate purposes of the system. For Duration/retention: Regularly review the necessity of retaining personal data and establish clear data deletion or anonymization procedures.
S	Fl	R	Location	Characteristics	Description																										
E2	DF3	P2	E3	DD4.1	Involved parties																										
E2	DF3	P2	DF3	DD3.3	Implicit data disclosure																										
E2	DF3	P2	P2	DD3.4	Duration/retention																										

DF5 (Data Flow)

Data Flow DF5 involves P2 Delivery sending delivery status updates and document IDs to E3 Email Provider to notify recipients. This communication may expose sensitive information if not properly secured, necessitating strict controls to ensure data confidentiality and integrity.

Number	Title	Type	Priority	Status	Score	Description	Mitigations																								
37	L on DF5	Non-repudiation	Medium	Open	5	Source (P2 Delivery): For the source, we need to consider potential privacy threats arising from the system's actions. Referring to Nr.1 in the Non-Repudiation tree, it's possible that we may be sending identifiable data, such as document IDs, to the third-party email provider. This information can be linked to individual users, allowing the provider to track specific actions, like delivery confirmations, and potentially attribute them to particular users. This raises privacy concerns as the email provider should ideally have limited access to identifiable personal data unless necessary. Data Flow : For the data flow, we must consider the potential risks due to actions taken by our system. Specifically, referencing threat Nr.1.3, metadata related to delivery status might be transmitted to a third-party email provider, which could intercept or log this information. Such metadata, if containing sensitive details about document status or recipient identity, should not be accessible by the email provider without strict privacy controls. Allowing access to this information without safeguards exposes sensitive data, potentially compromising privacy and contravening data protection standards. Destination (E3 Email Provider): For the destination, we need to evaluate potential risks arising from our system's actions. Specifically, referencing threat Nr.2, there's a possibility that the email provider may store or analyze document IDs and delivery statuses, which could allow them to track user actions or build profiles based on delivery patterns. Such tracking could lead to user actions being attributed back to them, compromising user privacy by enabling traceability without the user's consent, which is misaligned with privacy best practices. <table><tr><th>S</th><th>Fl</th><th>R</th><th>Location</th><th>Characteristics</th><th>Description</th></tr><tr><td>E3</td><td>DF5</td><td>P2</td><td>E3</td><td>Nr.1</td><td>Attributable data evidence</td></tr><tr><td>E3</td><td>DF5</td><td>P2</td><td>DF5</td><td>Nr.1.3</td><td>Metadata</td></tr><tr><td>E3</td><td>DF5</td><td>P2</td><td>P2</td><td>Nr.2</td><td>Attributable action side-effect evidence</td></tr></table>	S	Fl	R	Location	Characteristics	Description	E3	DF5	P2	E3	Nr.1	Attributable data evidence	E3	DF5	P2	DF5	Nr.1.3	Metadata	E3	DF5	P2	P2	Nr.2	Attributable action side-effect evidence	Data Encryption: Encrypt delivery status updates and document IDs to protect sensitive information during transmission. Minimize Data Sharing: Limit the amount of identifiable information sent to the email provider; only share what is strictly necessary. Metadata Anonymization: Remove or anonymize metadata related to delivery timing and recipient details to prevent unintended tracking. Data Retention Policy: Ensure the email provider follows a strict data retention policy, deleting delivery information once it is no longer needed. Contractual Agreement: Include privacy and data handling requirements in contracts with third-party providers to ensure compliance with privacy standards.
S	Fl	R	Location	Characteristics	Description																										
E3	DF5	P2	E3	Nr.1	Attributable data evidence																										
E3	DF5	P2	DF5	Nr.1.3	Metadata																										
E3	DF5	P2	P2	Nr.2	Attributable action side-effect evidence																										

DF2 (Data Flow)

Data Flow DF2 transfers essential banking information from Delivery (P2) to Banking (E2) to facilitate transaction processing, including transaction IDs and payment details. This flow supports accurate billing and efficient payment workflows between delivery and banking services.

Number	Title	Type	Priority	Status	Score	Description	Mitigations																								
43	L on DF2	Non-compliance	Medium	Open	7	Provide Source (P2 Delivery): Examining the data flow within our system, potential threats arise from the way the Delivery Process handles sensitive information. According to threat Nc.2, there is a risk that financial data could be managed improperly if it lacks essential security measures like encryption or restricted access. This could lead to the exposure of personal data, especially if the delivery system inadvertently shares financial details with third-party entities, violating privacy laws such as GDPR and compromising user data confidentiality. a description for this threat. Data Flow : Reviewing the data transfer process, there are potential threats stemming from inadequate cybersecurity risk management, specifically under threat Nc.3. The transfer of financial data may lack sufficient protection mechanisms, such as encryption, which exposes sensitive information during transit. This vulnerability increases the risk of unauthorized interception, compromising data privacy and potentially breaching compliance standards for secure data handling. Destination (E2 Banking): Considering the destination of the data, there are potential threats related to privacy non-compliance, particularly under threat Nc.4. The banking service receiving the data might not adhere to all required privacy standards, which raises concerns about unauthorized processing or improper storage of financial information. This lack of compliance could result in data being handled in ways that compromise user privacy, potentially exposing sensitive information without sufficient safeguards, thereby violating privacy regulations and diminishing user trust. <table><tr><th>S</th><th>Fl</th><th>R</th><th>Location</th><th>Characteristics</th><th>Description</th></tr><tr><td>P2</td><td>DF2</td><td>E2</td><td>P2</td><td>Nc.2</td><td>Improper personal data management</td></tr><tr><td>P2</td><td>DF2</td><td>E2</td><td>DF5</td><td>Nc.3</td><td>Insufficient cybersecu- rity risk management</td></tr><tr><td>P2</td><td>DF2</td><td>E2</td><td>E2</td><td>Nc.4</td><td>Non-compliance with privacy standards and best practices</td></tr></table>	S	Fl	R	Location	Characteristics	Description	P2	DF2	E2	P2	Nc.2	Improper personal data management	P2	DF2	E2	DF5	Nc.3	Insufficient cybersecu- rity risk management	P2	DF2	E2	E2	Nc.4	Non-compliance with privacy standards and best practices	Data Encryption: Ensure all financial data transferred from P2 Delivery to E2 Banking is encrypted both in transit and at rest to prevent unauthorized access. Access Control: Implement strict access controls, limiting data access to authorized personnel only, both within P2 Delivery and E2 Banking. Compliance Audits: Regularly audit both the Delivery (P2) and Banking (E2) systems to verify compliance with privacy regulations (e.g., GDPR). Data Minimization: Transmit only the essential information required for transaction processing, reducing exposure of unnecessary sensitive data.
S	Fl	R	Location	Characteristics	Description																										
P2	DF2	E2	P2	Nc.2	Improper personal data management																										
P2	DF2	E2	DF5	Nc.3	Insufficient cybersecu- rity risk management																										
P2	DF2	E2	E2	Nc.4	Non-compliance with privacy standards and best practices																										

STRIDE

Owner: Rehanah Bugis - Ghadah Alharthi - Renad Albladi - Raghad Alowaybidi
Reviewer: Identifying specific security threats and vulnerabilities using STRIDE - Analyzing the impact of potential security breaches.
Contributors:
Date Generated: Tue Oct 29 2024

Executive Summary

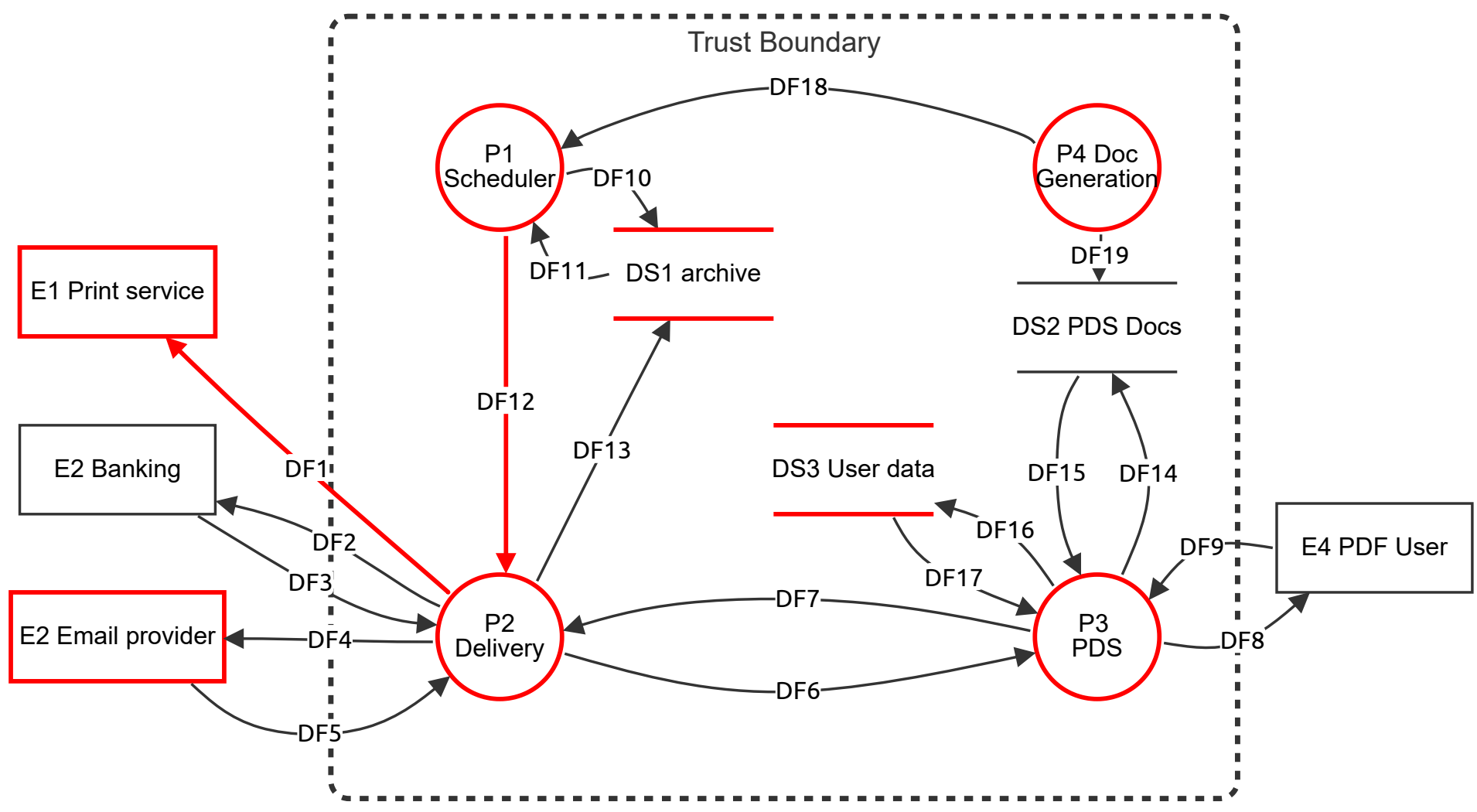
High level system description

This data flow diagram (DFD) presents a system that processes and delivers various types of data.

Summary

Total Threats	12
Total Mitigated	0
Not Mitigated	12
Open / High Priority	3
Open / Medium Priority	8
Open / Low Priority	1
Open / Unknown Priority	0

New STRIDE diagram



New STRIDE diagram

P1 Scheduler (Process)

Number	Title	Type	Priority	Status	Score	Description	Mitigations
27	(12) Elevation of Privilege on P1 Scheduler	Elevation of privilege	Medium	Open	3	An attacker could gain unauthorized access to the P1 Scheduler and manipulate its functions.	Implement strong access controls and role-based access control (RBAC) for P1 Scheduler.

E1 Print service (Actor)

Number	Title	Type	Priority	Status	Score	Description	Mitigations
9	(1) Spoofing of E1 Print Service	Spoofing	Medium	Open	3	An attacker could impersonate the E1 Print Service to gain unauthorized access to the system or to send malicious print jobs.	Implement strong authentication mechanisms for the E1 Print Service, such as certificates or multi-factor authentication.

E2 Email provider (Actor)

Number	Title	Type	Priority	Status	Score	Description	Mitigations
15	(6) Repudiation of E2 Email Provider	Repudiation	Low	Open	2	An attacker could deny sending malicious emails through the E2 Email Provider.	Implement strong authentication and authorization mechanisms for the E2 Email Provider.

P4 Doc Generation (Process)

Number	Title	Type	Priority	Status	Score	Description	Mitigations
10	(2) Spoofing of P4 Doc Generation	Spoofing	Medium	Open	3	An attacker could impersonate the P4 Doc Generation process to gain unauthorized access to sensitive data or to generate malicious documents.	Implement strong access controls to the P4 Doc Generation process, such as role-based access control (RBAC).
14	(5) Repudiation of P4 Doc Generation	Repudiation	Medium	Open	3	An attacker could deny responsibility for actions taken by the P4 Doc Generation process, such as sending malicious documents.	Implement logging and auditing mechanisms to track activities of the P4 Doc Generation process.
31	(10) Denial of Service Attack on P4 Doc Generation	Denial of service	Medium	Open	3	An attacker could overload P4 Doc Generation with malicious requests, preventing legitimate document generation requests from being processed.	Consider using a load balancer to distribute incoming traffic across multiple instances of P4 Doc Generation.

P2 Delivery (Process)

Number	Title	Type	Priority	Status	Score	Description	Mitigations
19	(9) Denial of Service Attack on P2 Delivery	Denial of service	High	Open	4	An attacker could overload P2 Delivery with malicious requests, preventing legitimate requests from being processed.	Implement rate limiting and intrusion detection systems to protect P2 Delivery.

P3 PDS (Process)

Number	Title	Type	Priority	Status	Score	Description	Mitigations
26	(11) Elevation of Privilege on P3 PDS	Elevation of privilege	High	Open	4	An attacker could gain unauthorized access to sensitive data stored in P3 PDS.	Implement strong access controls and role-based access control (RBAC) for P3 PDS.

DF12 (Data Flow)

Number	Title	Type	Priority	Status	Score	Description	Mitigations
17	(8) Information Disclosure of DF12	Information disclosure	Medium	Open	3	Sensitive data flowing through DF12 could be intercepted and disclosed.	Implement encryption and secure communication protocols for DF12.

DF1 (Data Flow)

Number	Title	Type	Priority	Status	Score	Description	Mitigations
18	(4) Tampering with DF1	Tampering	Medium	Open	3	An attacker could modify the data flow DF1, leading to incorrect data being processed by P2 Delivery.	Implement data validation and integrity checks for DF1.

DS1 archive (Store)

Number	Title	Type	Priority	Status	Score	Description	Mitigations
11	(3) Tampering with DS1 Archive	Tampering	Medium	Open	4	An attacker could modify or delete data in the DS1 archive, leading to data loss or corruption.	Implement data integrity checks and backups for the DS1 archive.

DS3 User data (Store)

Number	Title	Type	Priority	Status	Score	Description	Mitigations
16	(7) Information Disclosure of DS3 User Data	Information disclosure	High	Open	4	Sensitive user data in DS3 could be exposed to unauthorized individuals.	Implement strong access controls and encryption for DS3.